

Humanify — Quality Assurance, Quality Control & Release Strategy

Version: 2.0

Evidence cutoff: 30 July 2026

Audience: QA, engineering, product, operations, enterprise diligence.

1. Quality objective

Humanify quality assurance prioritizes business-impact failures:

1. Prevent cross-tenant data exposure.
2. Prevent incorrect payroll, tax, balance, and financial state.
3. Preserve authenticated ESS/MSS and approval journeys.
4. Keep production deployable, observable, and recoverable.
5. Prevent hidden/lab features from being represented as GA.

Test files existing in the repository and test results recorded as green are different evidence classes. This document keeps them separate.

2. Quality model

Blocker

- Cross-tenant/IDOR leak.
- Unauthorized payroll or private-document access.
- Corrupt or materially wrong payroll.
- Authentication bypass.
- Production unavailable with no viable rollback.

Release action: stop promotion or roll back immediately.

Major

- Critical workflow cannot complete.
- Approval state is wrong or non-auditable.
- Attendance/payroll bridge breaks.
- Claims evidence cannot be securely accessed.
- Feature entitlement can be bypassed.

Release action: block affected release unless formally isolated and accepted.

Minor

- Copy, spacing, non-critical visual inconsistency.

- Non-blocking empty-state or secondary CTA issue.
- Cosmetic chart or responsive issue without data loss.

Release action: track and schedule; may ship with product approval.

3. Test layers

Unit tests

Repository Jest coverage includes shared middleware tests such as:

- Tenant isolation.
- withHQAAuth.
- Rate limiting.

Commands:

- `npm test`
- `npm run test:ci`
- `npm run test:coverage`

Current limitation: no recent documented clean Jest run, coverage percentage, or enforced coverage threshold is tied to the latest Humanify release.

Static and contract checks

Humanify CI includes:

- Filtered TypeScript validation.
- Required-file checks.
- No-network logic/smoke scripts.
- `lint:humanify-hq-auth`.
- Build artifact checks.

Limitations:

- Next.js production build skips TypeScript and ESLint validation.
- Generic CI tolerates lint/Jest failures.
- Humanify workflow path filters omit some frontend, HR library, test, script, and style paths.

API and module smoke tests

The repository contains broad script coverage across:

- Tenant isolation and empty tenants.
- Signup, plans, billing, invites, and onboarding.
- Employees, documents, attendance, leave, claims, assets, lifecycle.
- Payroll, fiscal calculations, audit states, and disbursement.
- KPI, performance, analytics, recruitment, LMS, SSO, API, and platform ops.

- Mock guards, rate limiting, headers, Redis, observability, and health.

Key commands:

- `npm run smoke:ci-subset`
- `npm run qa:humanify-full`
- `npm run qa:humanify:matrix`
- `npm run smoke:payroll-golden`
- `npm run smoke:claim-proof`
- `npm run smoke:ga-journey`
- `npm run smoke:kpi-performance`
- `npm run smoke:sidebar-persona`

Playwright E2E

Humanify E2E covers selected:

- Public/auth pages.
- Authenticated HR pages.
- Payroll.
- RBAC personas.
- ESS.
- Manager leave approval.
- Documents and module routes.

Key commands:

- `npm run test:e2e:humanify:prod`
- `npm run test:e2e:humanify:payroll:prod`
- Staging-gated hard payroll and persona suites.

Current limitations:

- Secret-dependent suites may skip and still leave CI green.
- Chromium is the primary configured browser.
- No consolidated current green across every Humanify Playwright spec.
- No formal mobile device, Firefox, WebKit, or accessibility matrix.

Security testing

Present:

- IDOR packs and weekly security scorecard.
- Strict RLS staging lab.
- Job/cron tenant-context chaos.
- OWASP-oriented probes.
- Login lockout and rate-limit checks.
- Trivy filesystem dependency/image scan workflow.

Commands:

- `npm run smoke:idor`
- `npm run security:scorecard`
- `npm run security:owasp`
- `npm run smoke:rls-lab`
- `npm run smoke:rls-job-chaos`

Current limitations:

- OWASP and Trivy have no recent green evidence recorded in the handoff.
- Weekly scorecard is a selected subset, not every IDOR test.
- CSRF evidence should explicitly assert rejection rather than count successful foreign-origin handling as acceptable.
- Strict RLS evidence applies to staging, not production policy mode.

Performance and resilience

Present:

- Light concurrency/stress within selected KPI, enterprise, employee, dashboard, recruitment, attendance, and HR scripts.
- Latency thresholds in selected smoke tests.
- Health, Redis, backup-freshness, SMTP, and uptime checks.

Missing:

- Sustained load.
- Soak tests.
- Capacity by plan/tenant size.
- Database saturation and connection-pool tests.
- Memory leak tests.
- Web Vitals budgets.
- Multi-instance behavior.
- Disaster recovery exercise attached to each release.

4. Environments

Local

- Base: `http://localhost:3010`.
- Used for development, no-network tests, and selected Playwright.
- Local data does not prove production tenant isolation.

Staging

- Base: `https://staging.humanify.id`.
- Port: 3021.

- Strict RLS database.
- Required environment for hard payroll, strict isolation, and destructive end-to-end tests.
- Loopback staging is discouraged because NextAuth cookie/domain behavior can invalidate authenticated E2E.

Production

- Base: `https://humanify.id`.
- Port: 3020.
- Request-bound soft RLS.
- Only production-safe, non-destructive checks should run.
- Authenticated live checks require protected credentials.

5. Release gates

Gate A — build and availability

Required:

- Dependency install succeeds.
- Production build succeeds.
- `.next/BUILD_ID` exists.
- PM2 process is online.
- Local `/api/health` returns 200.
- Public `/api/health` returns 200.
- Login route returns 200.

Gate B — security and isolation

Required:

- `lint:humanify-hq-auth`.
- Security scorecard/IDOR subset.
- Plan and persona authorization checks.
- Strict RLS and job-context checks on staging when relevant.
- No open blocker security defect.

Gate C — business integrity

Required:

- `smoke:payroll-golden`.
- `smoke:claim-proof`.
- Module-specific critical smoke for changed areas.
- Audit state assertions for payroll changes.

Gate D — journeys and UI

Required:

- Persona/sidebar regression.
- GA journey.
- Affected authenticated E2E.
- Critical mobile ESS spot-check.
- Empty/error states for changed modules.

Gate E — operations and rollback

Recommended as mandatory:

- Migration set recorded and successful.
- Backup freshness confirmed.
- Rollback target known.
- Post-deploy smoke artifacts stored.
- Release notes link code, migration, tests, and environment.

6. Recorded evidence

The following is historical evidence from `.hermes/HANDOFF.md`, not a rerun performed by this documentation task:

- Wave 78, production: KPI/performance smoke 55 passed, 0 failed.
- Wave 76: employee avatar smoke 15 passed, 0 failed.
- Wave 75, production: go-live 10/0, claim-proof 28/0, sidebar persona 16/0, deployment health 200.
- Wave 73, staging and production: go-live 6/0 each, claim-proof 25/0 each.
- Wave 72, staging and production: HR wave UAT 12/0.
- Wave 69 gates: health/login 200; security scorecard 38/0 on staging and production; payroll 17/0; claim and GA journey green.
- Wave 67, staging: strict empty tenant context returned zero employee rows; IDOR and scorecard green.
- Wave 64, staging: payroll golden 17/0 and hard payroll E2E passed.
- 15 July baseline, production: 26-script regression recorded as 199/0, with a wording inconsistency around password-reset coverage that should be resolved before citing externally.

Evidence warning:

- HANDOFF is narrative operational evidence.
- It is not an immutable CI artifact.
- It does not prove that every current uncommitted worktree change is green.

7. QA matrix by product risk

Tenant and authorization changes

Minimum:

- Unit scope test.
- `lint:humanify-hq-auth`.
- Relevant IDOR batch.
- Persona/role E2E.
- Empty-tenant check.
- Staging strict RLS check when query shape changes.

Payroll/fiscal changes

Minimum:

- Calculation fixtures.
- Payroll golden.
- Attendance-to-payroll bridge.
- Approve-to-paid audit assertion.
- Payslip authorization.
- Finance sign-off update.

Files and claims

Minimum:

- Upload size/type validation.
- Private storage location.
- Authorized preview.
- Unauthorized and cross-tenant denial.
- Legacy receipt behavior.
- Backup/retention impact.

Billing and plans

Minimum:

- Quote and annual discount.
- PPN split.
- Webhook signature.
- Idempotency.
- Plan activation.
- Route and API entitlement.
- Downgrade seat guard.

UI and navigation

Minimum:

- Page crawl/no 5xx.
- Role/sidebar visibility.
- Keyboard and focus behavior.
- Loading, empty, error, success states.
- Mobile critical journey.
- No hidden/lab surface accidentally exposed.

8. Test data policy

- Production mock HR fallback is prohibited.
- Demo and QA tenants must be identifiable and excluded from commercial MRR.
- Smoke tests should create isolated, traceable records and clean them where safe.
- Tests must not depend on one permanent shared superadmin when persona behavior is under test.
- Production destructive tests are prohibited.
- Credentials and PII must not appear in test logs or repository artifacts.

9. CI/CD quality gaps

1. No single immutable release bundle with JUnit, Playwright, scorecard, and coverage artifacts.
2. No current enforced Jest coverage threshold.
3. Generic CI treats lint and Jest as non-blocking.
4. Humanify path filters miss relevant files.
5. Secret-dependent checks can skip and still pass.
6. Scheduled production QA can succeed without credentials.
7. No complete browser/device/accessibility matrix.
8. OWASP and Trivy lack current recorded green evidence.
9. Performance evidence is light concurrency, not capacity testing.
10. Manual deploy tolerates some migration and post-deploy failures.
11. Rollback and restore are documented but not attached to every release.

10. Improvement roadmap

P0

- Publish immutable test artifacts per release.
- Make missing required credentials a failed release gate, not a skip.
- Expand CI path filters to all Humanify components, libraries, styles, tests, scripts, APIs, pages, and migrations.
- Make lint, targeted typecheck, Jest, critical migrations, and post-deploy health blocking.
- Add regression tests for source-backed fail-open risks.

P1

- Establish coverage thresholds for tenant/auth/payroll/file domains.
- Add Firefox, WebKit, mobile viewport, and accessibility checks.
- Add sustained load and database capacity tests.
- Add automated rollback and scheduled restore drills.
- Produce a signed QC release record.

P2

- Contract testing for external providers.
- Chaos testing for Redis, SMTP, storage, DB failover, and provider outages.
- SLO error budgets and release quality trend dashboard.

11. Release sign-off template

Every production release record should include:

- Release ID / commit SHA.
- Product owner approval.
- Changed modules.
- Database migrations.
- Security impact.
- Gate A–E results.
- Test artifact links.
- Known limitations.
- Backup/rollback target.
- Deployment timestamp and operator.
- Post-deploy health and critical journey results.
- Final QC decision: pass, conditional pass, or rollback.

12. Key references

- `.github/workflows/humanify-saas-gate.yml`
- `.github/workflows/humanify-qa.yml`
- `.github/workflows/security.yml`
- `scripts/run-humanify-qa-matrix.sh`
- `scripts/run-humanify-full-qa.sh`
- `scripts/run-humanify-idor-smokes.sh`
- `scripts/deploy-humanify-vps.sh`
- `e2e/humanify*.spec.ts`
- `.hermes/HANDOFF.md`
- `.hermes/DECISIONS.md`